Università Politecnica delle Marche

Dipartimento di Ingegneria dell'Informazione



SOFTWARE SECURITY E BLOCKCHAIN

Laurea Magistrale in Ingegneria Informatica e dell'Automazione

Certificati di sicurezza e SBOM per gli sviluppatori di software

Progettazione di software sicuro e blockchain

GRUPPO DI LAVORO

Nicola De Cinque S000001
Serena Stefano S000002
Alessandro Stella 1137420
Gabriele Vianello S000004

DOCENTE

Prof. Luca Spalazzi

ASSISTENTE DEL DOCENTE

Dott. Tariq

Anno accademico 2026/2027 ▪ 2 novembre 2026

https://github.com/BlockchainzGurus/eth-adam



sha256: 9f86d081884c7d659a2feaa0c55ad015a3bf4f1b2b0b822cd15d6c15b0f00a08

Abstract

Questo progetto affronta la progettazione di software sicuro lungo tutta la catena di fornitura, combinando *certificati di sicurezza* e *Software Bill of Materials* (SBOM) per fornire agli sviluppatori garanzie verificabili sull'origine e sull'integrità dei componenti utilizzati. La tecnologia blockchain è impiegata come registro non modificabile per l'ancoraggio dei certificati e degli hash delle SBOM.

[TODO: Completare l'abstract con obiettivi, metodo e risultati ottenuti.]

Indice

Abstract **i**

1 Introduzione **1**
1.1 Contesto e motivazione . . . 1
1.2 Obiettivi del progetto . . . 1
1.3 Contributi . . . 1
1.4 Struttura della relazione . . . 1

2 Stato dell'arte **2**
2.1 Sicurezza della supply chain del software . . . 2
2.2 Software Bill of Materials . . . 2
2.3 Certificati di sicurezza e firma del software . . . 2
2.4 Blockchain per l'integrità e la tracciabilità . . . 2

3 Requisiti e modello delle minacce **3**
3.1 Attori e casi d'uso . . . 3
3.2 Requisiti funzionali e non funzionali . . . 3
3.3 Modello delle minacce . . . 3

4 Progettazione **4**
4.1 Architettura generale . . . 4
4.2 Struttura della SBOM . . . 4
4.3 Certificati di sicurezza . . . 4
4.4 Ruolo della blockchain . . . 4

5 Implementazione **5**
5.1 Ambiente e strumenti . . . 5
5.2 Smart contract . . . 5
5.3 Generazione della SBOM . . . 5
5.4 Emissione e verifica dei certificati . . . 5

6 Valutazione **6**
6.1 Metodologia di test . . . 6
6.2 Analisi di sicurezza . . . 6
6.3 Costi e prestazioni . . . 6
6.4 Limiti della soluzione . . . 6

7 Conclusioni **7**

A Ripartizione del lavoro **8**

Bibliografia **9**

Elenco delle figure

4.1 Architettura di riferimento (esempio da adattare). 4

Elenco delle tabelle

2.1 Confronto tra formati SBOM (da completare). 2

3.1 Elenco dei requisiti. 3

A.1 Contributo dei componenti del gruppo. 8

Elenco dei listati

5.1 Esempio: registro di hash di certificati e SBOM. 5
5.2 Esempio di comando per generare una SBOM. 5

1 Introduzione

1.1 Contesto e motivazione

[TODO: Perché la sicurezza della supply chain software è un problema attuale; attacchi noti, normative e linee guida di riferimento.]

1.2 Obiettivi del progetto

[TODO: Elencare gli obiettivi: certificati di sicurezza per gli sviluppatori, generazione e verifica della sbom, ruolo della blockchain.]

1.3 Contributi

[TODO: Descrivere in modo sintetico i risultati originali del gruppo.]

1.4 Struttura della relazione

Il Capitolo 2 presenta lo stato dell'arte, il Capitolo 3 definisce requisiti e modello delle minacce, il Capitolo 4 descrive la progettazione, il Capitolo 5 l'implementazione, il Capitolo 6 la valutazione e il Capitolo 7 riporta le conclusioni.

2 Stato dell'arte

2.1 Sicurezza della supply chain del software

[TODO: Pratiche di sviluppo sicuro e riferimenti normativi, ad esempio [1].]

2.2 Software Bill of Materials

Una SBOM è un inventario strutturato dei componenti che compongono un software, con relazioni di dipendenza, versioni e licenze. I formati più diffusi sono *SPDX* [2] e *CycloneDX* [3].

Tabella 2.1: Confronto tra formati SBOM (da completare).

Aspetto	**SPDX**	**CycloneDX**
Ambito principale	**[TODO:]**	**[TODO:]**
Formati di serializzazione	**[TODO:]**	**[TODO:]**
Supporto a vulnerabilità	**[TODO:]**	**[TODO:]**

2.3 Certificati di sicurezza e firma del software

[TODO: Certificati X.509, firma del codice, attestazioni di provenienza e infrastrutture a chiave pubblica.]

2.4 Blockchain per l'integrità e la tracciabilità

[TODO: Registro distribuito, smart contract, ancoraggio di hash [4].]

3 Requisiti e modello delle minacce

3.1 Attori e casi d'uso

[TODO: Sviluppatore, verificatore, ente certificatore, consumatore del software.]

3.2 Requisiti funzionali e non funzionali

Tabella 3.1: Elenco dei requisiti.

ID	Tipo	Descrizione
RF-01	Funzionale	[TODO: Generazione della sbom a partire dal progetto.]
RF-02	Funzionale	[TODO: Emissione e verifica del certificato di sicurezza.]
RNF-01	Sicurezza	[TODO: Integrità e non ripudio dei certificati.]

3.3 Modello delle minacce

[TODO: Metodologia adottata (ad esempio STRIDE), asset, avversari, superfici di attacco e contromisure.]

4 Progettazione

4.1 Architettura generale

La Figura 4.1 mostra uno schema d'esempio dell'architettura; va adattato al progetto.

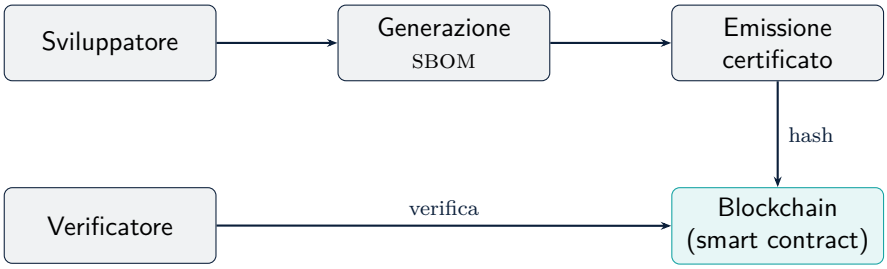


Figura 4.1: Architettura di riferimento (esempio da adattare).

4.2 Struttura della sbom

[TODO: Campi, formato scelto e motivazioni.]

4.3 Certificati di sicurezza

[TODO: Contenuto del certificato, catena di fiducia, ciclo di vita (emissione, revoca, scadenza).]

4.4 Ruolo della blockchain

[TODO: Dati ancorati on-chain, scelta della rete, costi e compromessi.]

5 Implementazione

5.1 Ambiente e strumenti

[TODO: Linguaggi, librerie, framework di sviluppo e test, rete di test.]

5.2 Smart contract

Il Listato 5.1 riporta un esempio minimale di registro di hash, da sostituire con il codice reale.

```
// SPDX-License-Identifier: MIT
pragma solidity ^0.8.20;

contract RegistroCertificati {
    mapping(bytes32 => address) public emittente;

    event Registrato(bytes32 indexed hash, address indexed da);

    function registra(bytes32 hash) public {
        require(emittente[hash] == address(0), "gia' registrato");
        emittente[hash] = msg.sender;
        emit Registrato(hash, msg.sender);
    }
}
```

Listato 5.1: Esempio: registro di hash di certificati e SBOM.

5.3 Generazione della sbom

```
# esempio generico: sostituire con lo strumento realmente utilizzato
cyclonedx-py environment -o sbom.json
```

Listato 5.2: Esempio di comando per generare una SBOM.

5.4 Emissione e verifica dei certificati

[TODO: Descrivere i flussi implementati e le scelte crittografiche.]

6 Valutazione

6.1 Metodologia di test

[TODO: Casi di test, strumenti di analisi statica e dinamica, ambiente.]

6.2 Analisi di sicurezza

[TODO: Verifica delle contromisure rispetto al modello delle minacce (Capitolo 3).]

6.3 Costi e prestazioni

[TODO: Costo del gas, tempi di generazione e verifica, scalabilità.]

6.4 Limiti della soluzione

[TODO: Limiti noti e lavori futuri.]

7 Conclusioni

[TODO: Riepilogo dei risultati rispetto agli obiettivi dell'Introduzione e possibili sviluppi futuri.]

A Ripartizione del lavoro

Tabella A.1: Contributo dei componenti del gruppo.

Studente	**Attività svolte**
Nicola De Cinque	**[TODO:]**
Serena Stefano	**[TODO:]**
Alessandro Stella	**[TODO:]**
Gabriele Vianello	**[TODO:]**

[1] National Institute of Standards and Technology. *Secure Software Development Framework (SSDF) Version 1.1*. Special Publication 800-218. NIST, 2022.

[2] ISO/IEC. *ISO/IEC 5962:2021 – Information technology – SPDX Specification V2.2.1*. 2021.

[3] OWASP Foundation. *CycloneDX Bill of Materials Specification*. URL: `https://cyclonedx.org/specification/overview/`.

[4] Satoshi Nakamoto. *Bitcoin: A Peer-to-Peer Electronic Cash System*. 2008.